МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ

Федеральное государственное автономное образовательное учреждение высшего образования

«Дальневосточный федеральный университет»
(ДВФУ)

ИНСТИТУТ МАТЕМАТИКИ И КОМПЬЮТЕРНЫХ ТЕХНОЛОГИЙ (ШКОЛА)

Департамент математического и компьютерного моделирования

Лабораторная работа №1

по теме: «Анализ рисков информационной безопасности», вариант 10

Выполнил студент
гр. Б9123-02.03.01сцт
Избосарова Жасмина Олимжоновна

г. Владивосток
2026

Содержание

Задание 2

1 Обоснование выбора информационных активов организации 2

2 Оценка ценности информационных активов 3

3 Уязвимости системы защиты информации 4

4 Угрозы ИБ 5

5 Оценка рисков 7

6 Выводы 8

7 Литература 8

Задание

В данной работе рассматривается дизайнерская фирма (вариант 10). Задание выполняется по методичке.

№	Формулировка задания
1	Загрузите ГОСТ Р ИСО/МЭК ТО 27005-2010 «МЕТОДЫ И СРЕДСТВА ОБЕСПЕЧЕНИЯ БЕЗОПАСНОСТИ». Часть 3 «Методы менеджмента безопасности информационных технологий».
2	Ознакомьтесь с Приложениями C, D и E ГОСТа.
3	Выберите три различных информационных актива организации (см. вариант).
4	Из Приложения D ГОСТа подберите три конкретных уязвимости системы защиты указанных информационных активов.
5	Пользуясь Приложением C ГОСТа напишите три угрозы, реализация которых возможна пока в системе не устранены названные в пункте 4 уязвимости.
6	Пользуясь одним из методов предложенных в Приложении E ГОСТа произведите оценку рисков информационной безопасности.
7	Оценку ценности информационного актива производить на основании возможных потерь для организации в случае реализации угрозы.

Обоснование выбора информационных активов организации

Рассматривается небольшая дизайнерская фирма, которая занимается разработкой фирменного стиля, полиграфии, веб-дизайна и рекламных материалов для заказчиков. В штате около 15 человек: дизайнеры, менеджеры проектов и бухгалтер. Для работы нужны три вещи: файлы с проектами (макеты, исходники), рабочие компьютеры дизайнеров и электронная почта для общения с клиентами. Именно эти три актива и были выбраны — они покрывают и творческую часть, и рабочий процесс, и коммуникации.

№	Информационный актив	Назначение и обоснование выбора
1	Файловое хранилище проектов	Здесь лежат все рабочие файлы: макеты в Figma/Photoshop/Illustrator, исходники логотипов, вёрстка, шрифты. Это главный результат работы фирмы. Если файлы пропадут или утекут к конкурентам — фирма потеряет и работу, и доверие клиентов.
2	Рабочие станции дизайнеров	Компьютеры (обычно Mac или мощные ПК), на которых стоят лицензионные программы: Adobe Creative Cloud, Figma, CorelDRAW. На них ведётся вся работа. Поломка или заражение вирусом означает простой.
3	Корпоративная электронная почта	Через почту идёт переписка с заказчиками: техзадания, правки, утверждение макетов, отправка готовых файлов. Также через неё приходят договоры и счета. Взлом почты — это и утечка информации, и потеря клиентов.

Все три актива связаны друг с другом: дизайнер работает на рабочей станции, сохраняет файлы в хранилище, а результат отправляет клиенту по почте. Если что-то из этого выйдет из строя или будет скомпрометировано, пострадает вся цепочка.

Оценка ценности информационных активов

Ценность каждого актива оценивается по тому, какие потери понесёт фирма, если с ним что-то случится. Фирма небольшая, поэтому суммы не такие большие, как в банке, но для маленькой компании они ощутимы. Используется шкала от 1 до 5 по примеру 2 из Приложения Е.2.2: 1 — минимальные потери, 5 — очень серьёзные.

№	Информационный актив	Возможные потери при реализации угрозы	V (1–5)	Обоснование
1	Файловое хранилище проектов	Около 1,5 млн руб.: переделка утраченных проектов, срыв сроков, штрафы по договорам, потеря клиентов из-за утечки их материалов.	5	Это основной продукт работы фирмы. Потеря файлов — потеря всего.
2	Рабочие станции дизайнеров	Около 500 тыс. руб.: простой сотрудников, покупка/переустановка ПО, восстановление локальных файлов.	3	Неприятно, но восстановить можно за несколько дней. Лицензии привязаны к аккаунтам, а не к железу.
3	Корпоративная электронная почта	Около 800 тыс. руб.: утечка переписки с клиентами, потеря контактов, рассылка спама от имени фирмы, репутационный ущерб.	4	Почта — лицо компании. Взлом сильно бьёт по репутации.

Уязвимости системы защиты информации

Уязвимости взяты из Приложения D, таблица D.1. Для каждого актива подобрана та уязвимость, которая реально может встретиться в небольшой дизайнерской фирме, где обычно нет выделенного сисадмина и вопросы безопасности решаются «по ходу дела».

№	Информационный актив	Вид	Конкретная уязвимость из Приложения D	Связанная примером угроза
1	Файловое хранилище проектов	Программные средства	Отсутствие резервных копий	Искажение данных
2	Рабочие станции дизайнеров	Персонал	Ненадлежащее использование программных и аппаратных средств	Ошибка в использовании
3	Корпоративная электронная почта	Сеть	Передача паролей в открытом виде	Перехват информации

Уязвимости выбраны не случайно. В маленькой фирме часто нет бэкапов («да ладно, ничего не случится»), сотрудники ставят что попало на рабочие компьютеры, а пароли от почты бывают простыми или передаются в мессенджерах открытым текстом.

Угрозы ИБ

Угрозы подобраны из Приложения C, таблица C.1. «У» — умышленная угроза, «С» — случайная. Для каждой пары «уязвимость–актив» описан конкретный сценарий: что может случиться и как.

№	Уязвимость	Угроза ИБ из Приложения С	Тип	Сценарий возможного инцидента
1	Отсутствие резервных копий	Искажение данных	С	Дизайнер случайно удаляет папку с проектом крупного заказчика. Бэкапов нет, корзина очищена. Проект приходится делать заново, срок сорван, клиент уходит.
2	Ненадлежащее использование ПО и аппаратных средств	Ошибка в использовании	С	Сотрудник скачивает «бесплатный» плагин для Photoshop с сомнительного сайта. Вместе с плагином устанавливается вредоносная программа, которая шифрует файлы на компьютере. Работа останавливается, пока комп не переустановят.
3	Передача паролей в открытом виде	Перехват информации	У	Менеджер отправляет пароль от корпоративной почты новому сотруднику в обычном сообщении в Telegram. Злоумышленник, получивший доступ к одному из аккаунтов, видит пароль и заходит в почту фирмы. Читает переписку, скачивает файлы клиентов.

Эти три сценария вполне реалистичны для небольшой фирмы. Дальше на их основе считается риск.

Оценка рисков

Используется подход из Приложения Е, пример Е.2.2: риск считается как произведение ценности актива на вероятность реализации угрозы. Формула: $R = V \times P$.

Шкала вероятности:

P	**Степень вероятности**	**Что это значит**
1	Очень низкая	Маловероятно, нужно редкое стечение обстоятельств.
2	Низкая	Может случиться, но нечасто.
3	Средняя	Вполне реальный сценарий.
4	Высокая	Скорее всего случится при текущих условиях.
5	Очень высокая	Случается регулярно или почти неизбежно.

Расчёт рисков:

№	**Актив**	**Уязвимость**	**Угроза**	**V**	**P**	**R**	**Ранг**
1	Файловое хранилище проектов	Отсутствие резервных копий	Искажение данных	5	4	20	1
2	Корпоративная электронная почта	Передача паролей в открытом виде	Перехват информации	4	3	12	2
3	Рабочие станции дизайнеров	Ненадлежащее использование ПО	Ошибка в использовании	3	3	9	3

Итоговое ранжирование:

Приоритет	**Сценарий**	**R**	**Итоговая оценка**
1	Потеря файлов проектов из-за отсутствия бэкапов	20	Очень высокий риск
2	Перехват пароля и взлом корпоративной почты	12	Высокий риск
3	Заражение рабочей станции из-за скачивания сомнительного ПО	9	Средний риск

Самый опасный сценарий — потеря проектных файлов ($R = 5 \times 4 = 20$). Вероятность поставлена 4, потому что в маленьких фирмах бэкапы часто не делаются вообще. На втором месте — перехват пароля от почты ($R = 4 \times 3 = 12$). На третьем — заражение рабочей станции ($R = 3 \times 3 = 9$).

Выводы

В работе были рассмотрены три информационных актива дизайнерской фирмы: файловое хранилище проектов, рабочие станции дизайнеров и корпоративная электронная почта.

Для каждого актива определена ценность от 3 до 5 по пятибалльной шкале. Самым ценным оказалось хранилище проектов — потеря файлов для дизайнерской фирмы фактически означает потерю результатов работы.

Из Приложения D подобраны три уязвимости: отсутствие бэкапов, небрежное обращение с ПО и передача паролей в открытом виде. Каждой уязвимости сопоставлена угроза из Приложения C.

По методу E.2.2 получены меры риска: 20, 12 и 9. Главный риск — потеря данных без возможности восстановления. Чтобы его снизить, нужно в первую очередь настроить автоматическое резервное копирование (хотя бы в облако). Кроме того, стоит ввести правило не передавать пароли через мессенджеры и не скачивать программы из непроверенных источников.

Литература

1. ГОСТ Р ИСО/МЭК 27005-2010, Приложения C, D и E.